PRACTICAL 10

Secure Login/Logout with Sessions, Role-Based Access, Timeout, and Remember-Me Token

AIM

To implement secure login and logout in StudentHub using PHP sessions, verify passwords, protect dashboards according to user roles, handle session timeout, and add a secure remember-me option.

Introduction

The StudentHub login form was connected to the users table created in Practical 9. Passwords are checked using password_verify(). After login, the session ID is regenerated and the user is redirected to the appropriate dashboard. Logout, unauthorized access and inactivity timeout were tested using sample accounts.

Tools and Technology

VS Code, XAMPP, PHP, MySQLi, MariaDB, phpMyAdmin, HTML, CSS, browser, Git and GitHub.

Files Used

File	Purpose
login.php	Login form, password verification and role redirect.
php/auth.php	Session settings, timeout, role checks and remember tokens.
dashboard.php	Protected student dashboard.
admin-dashboard.php / faculty-dashboard.php	Protected admin and faculty dashboards.
dashboard-router.php	Opens the dashboard matching the account role.
logout.php	POST logout, token revocation and session destruction.
php/access-denied.php	Unauthorized role message.
sql/practical10.sql	Admin role, last_login and remember_tokens table.
scripts/seed-practical10.php	Creates hashed student, admin and faculty lab accounts.

Key Skills Used

PHP sessions, cookies, password verification, session ID regeneration, role-based access, inactivity timeout, prepared statements, token hashing and logout.

Implementation Overview

1 Session Settings

PHP sessions use strict mode and cookie-only session IDs. Cookies are HttpOnly and SameSite=Lax. The Secure flag is enabled when the site uses HTTPS. Protected responses use Cache-Control: no-store.

2 Login and Password Verification

A prepared query finds the user by email. password_verify() checks the supplied password against the stored hash. Incorrect credentials display Invalid email or password. Successful login calls session_regenerate_id(true) before storing the user ID, name, role and activity time.

3 Role-Based Dashboards

Student, admin and faculty accounts open separate dashboards. Each dashboard checks the logged-in user and current database role before displaying content. A student opening the admin dashboard receives HTTP 403. Visitors without a session are sent to the login page.

4 Logout

The logout button submits a POST request with a CSRF token. The remember token is revoked, session data is cleared, the session cookie is expired and session_destroy() is called. The login page displays a logout confirmation.

5 Session Timeout

The server checks the time since the last authenticated request. After 15 minutes of inactivity, it clears the session and remember cookie and returns to login. A temporary two-second setting was used to test and capture timeout, then removed.

6 Last-Login Timestamp

The users table contains a last_login column. Successful password login and remember-me restoration update this timestamp. Database checks confirmed timestamps for all three lab accounts.

7 Remember-Me Token

Remember me creates a random selector and validator using random_bytes(). The database stores the SHA-256 hash of the validator with a 30-day expiry. The token is verified and rotated when restoring a session. Old and modified tokens are rejected. Logout and timeout revoke the token.

Screenshots of Successful Login and Role-Based Redirects

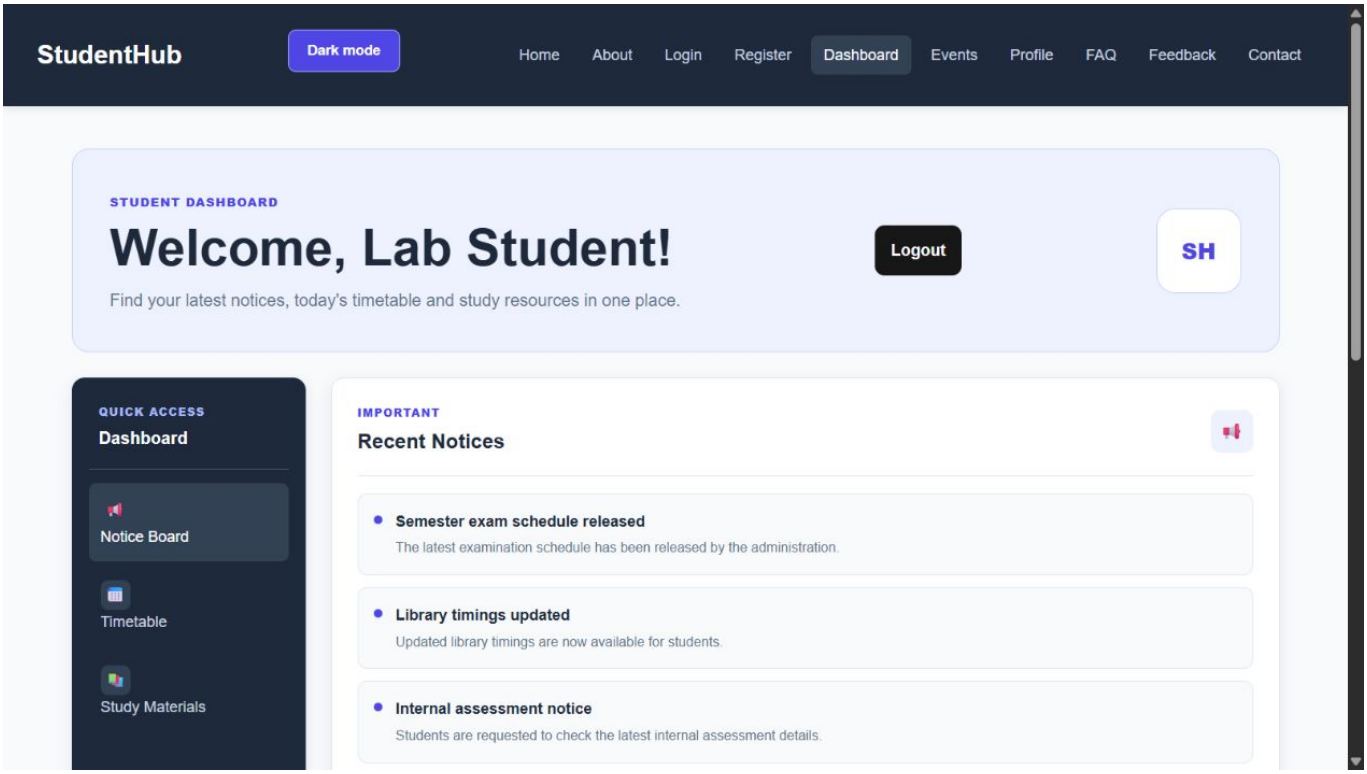


Figure 1: Successful student login displaying the student dashboard.

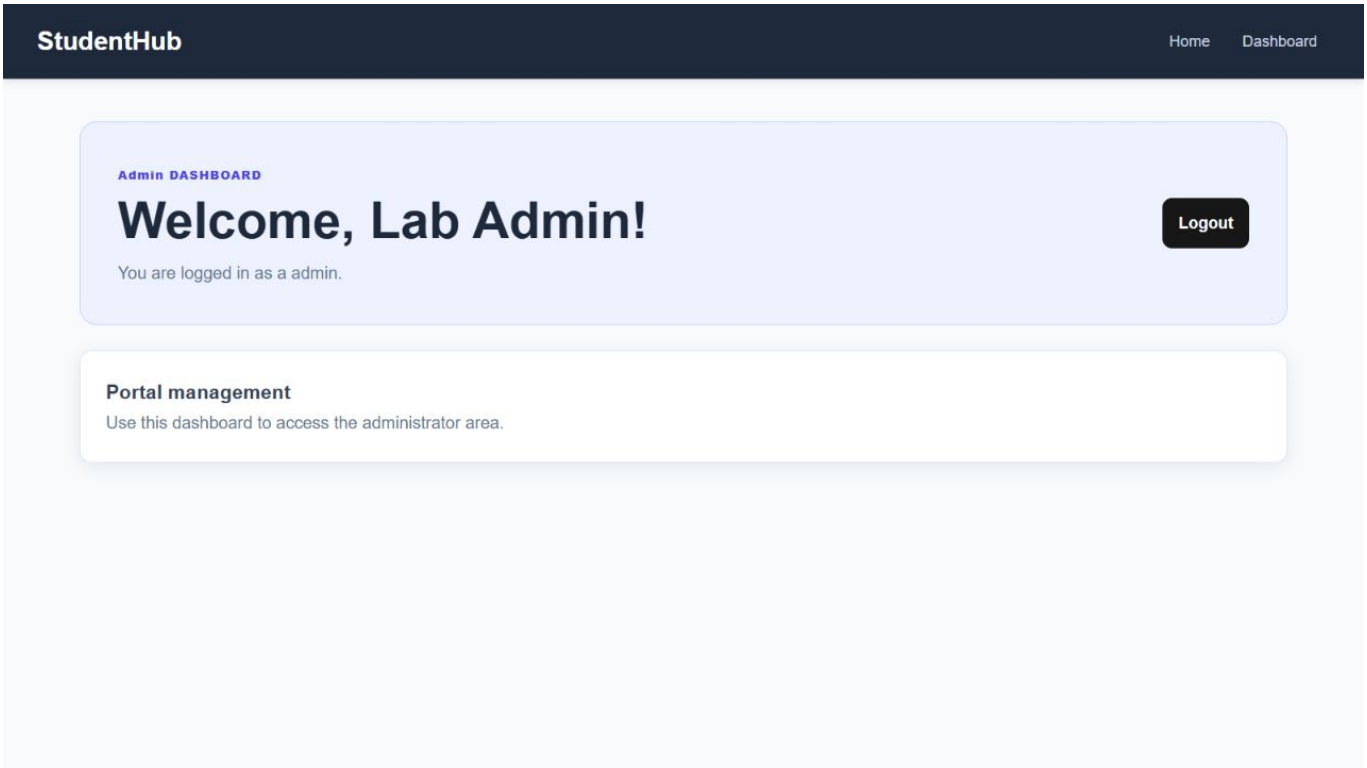


Figure 2: Successful admin login displaying the admin dashboard.

Screenshots of Failed Login and Logout

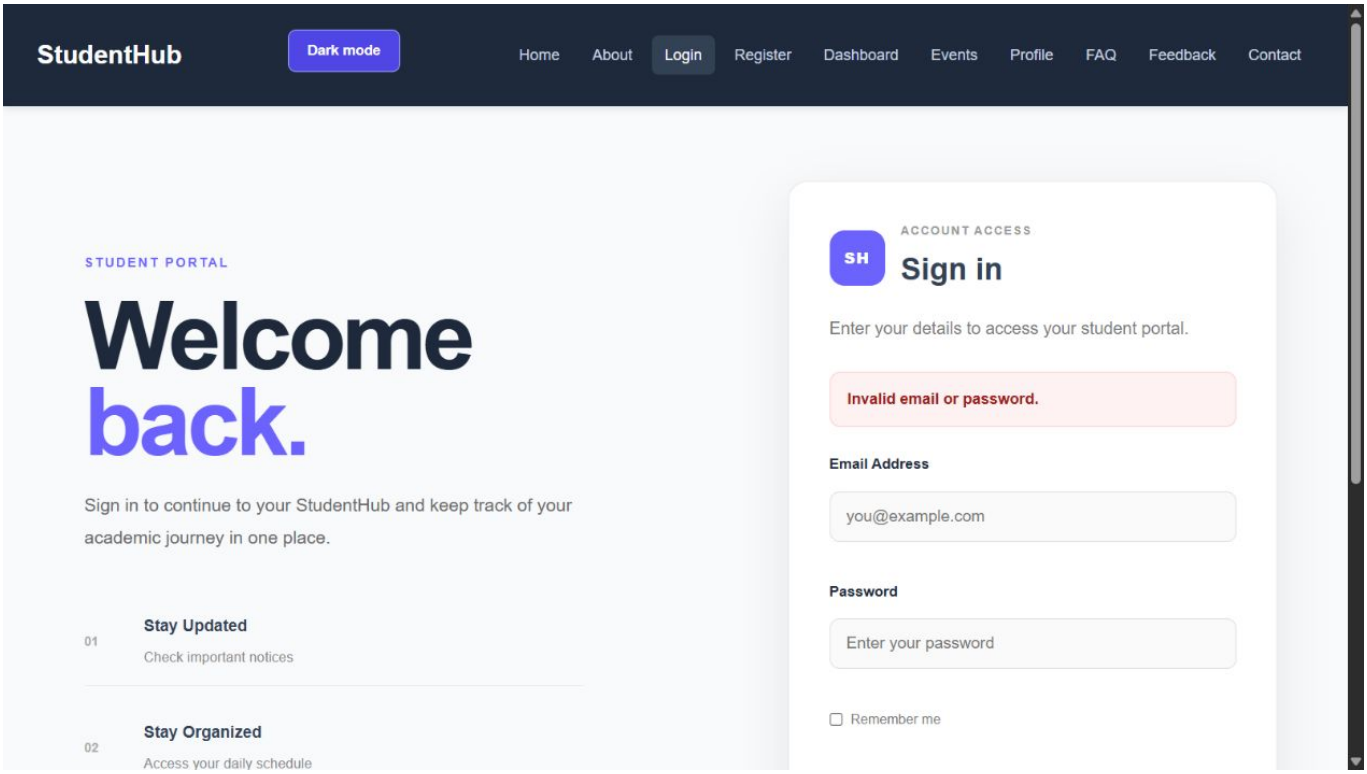


Figure 3: Incorrect password displaying the failed-login message.

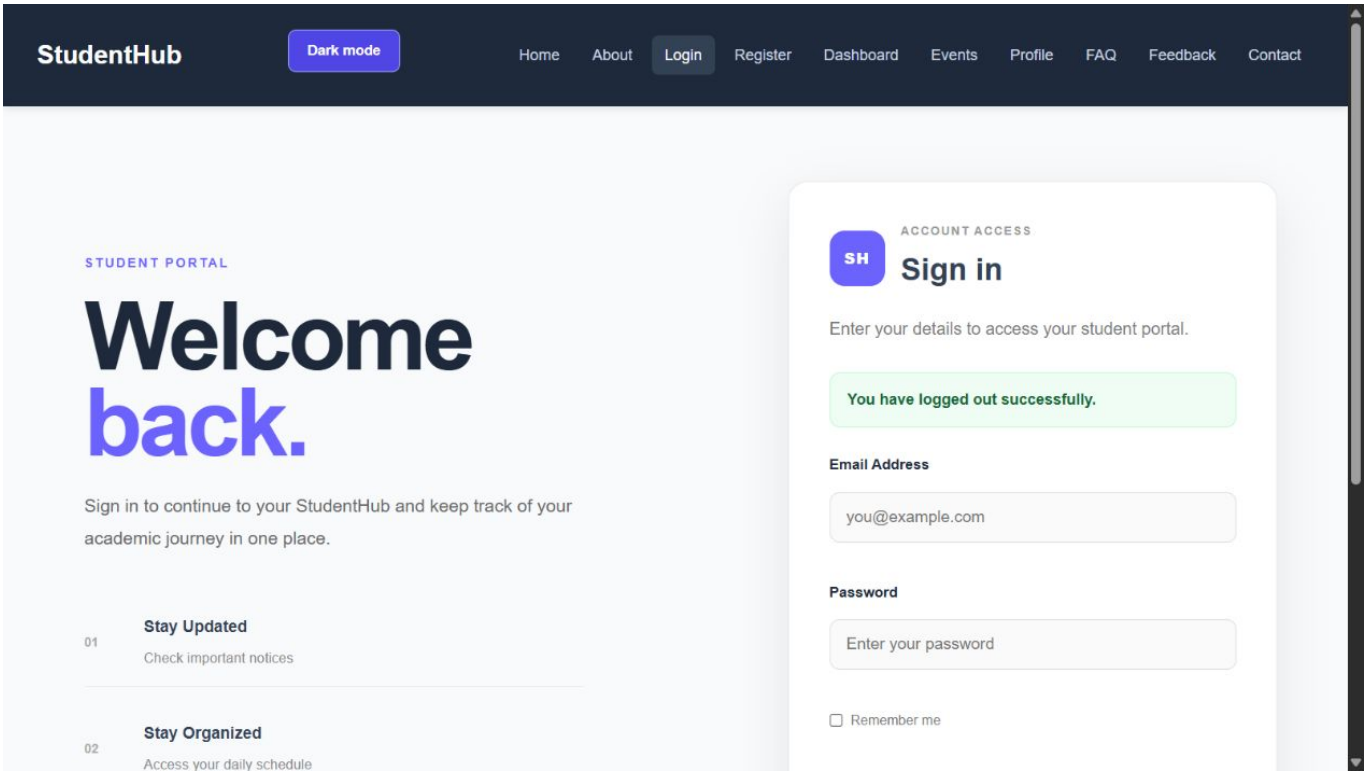


Figure 4: Successful logout returning the user to the login page.

Screenshots of Timeout and Unauthorized Role Access

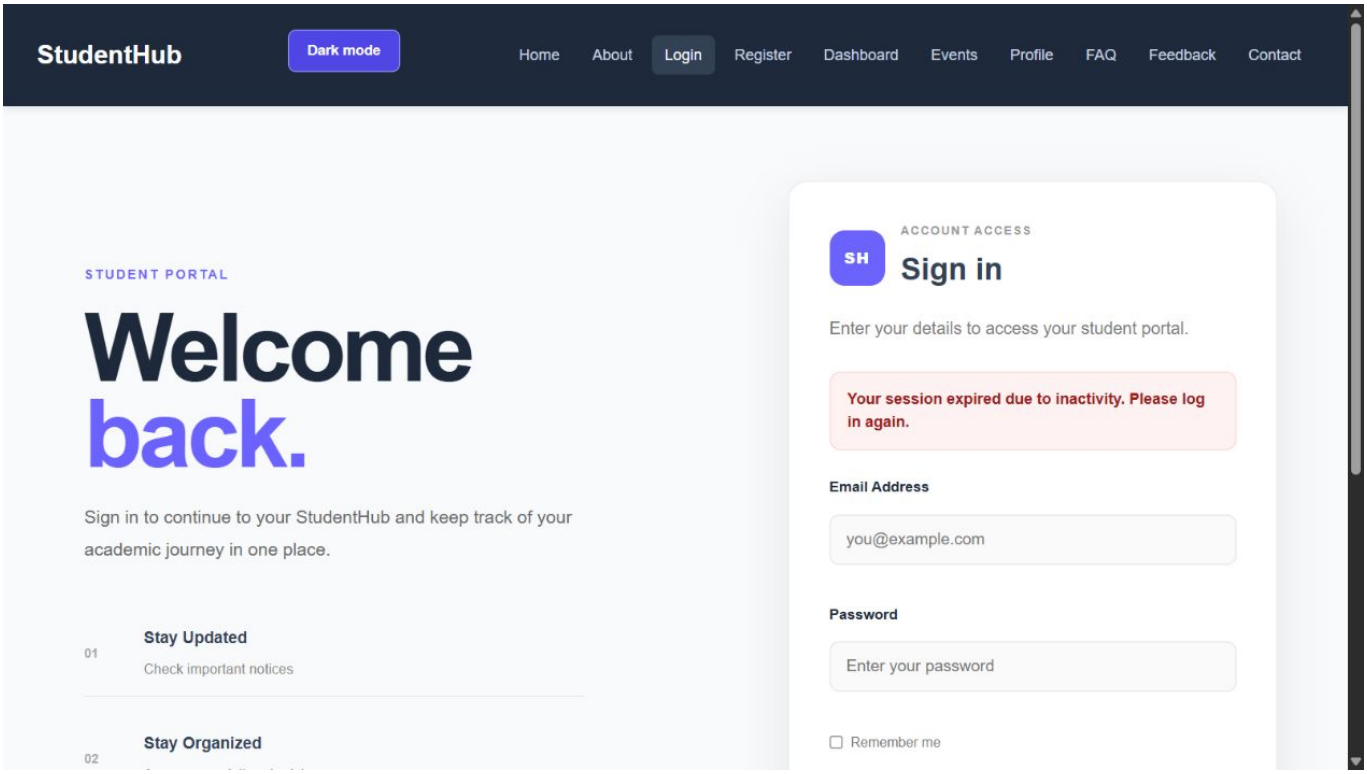


Figure 5: Expired session displaying the inactivity-timeout message.

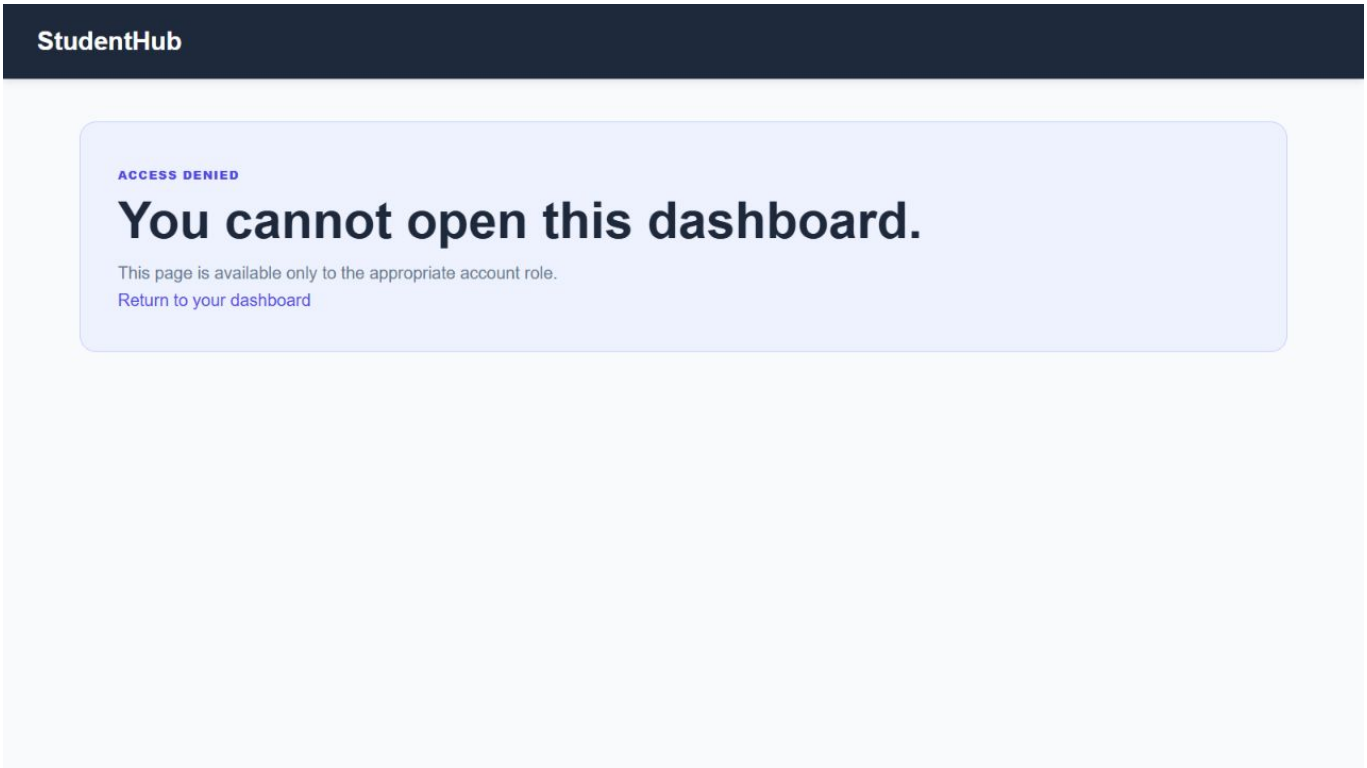


Figure 6: A student account is blocked from opening the admin dashboard.

Unauthorized Access and Testing Summary

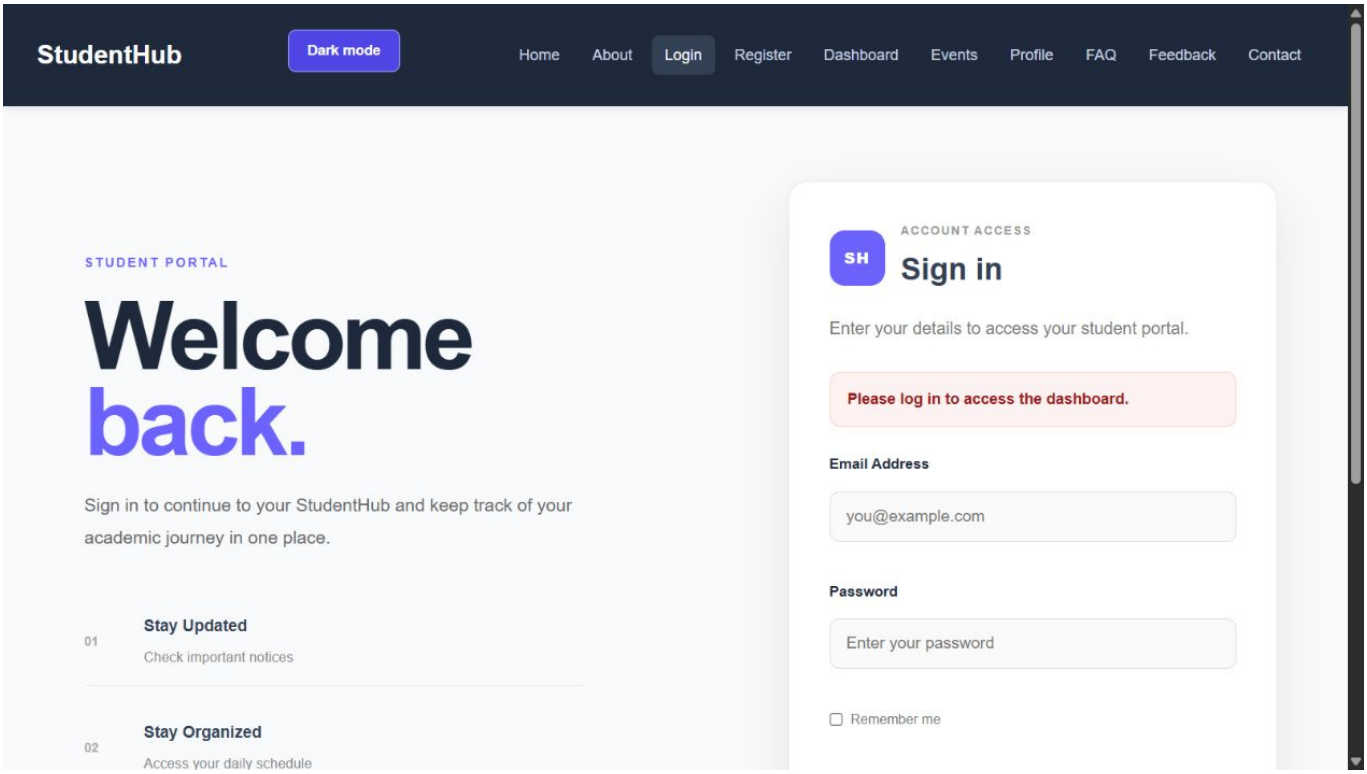


Figure 7: Opening the dashboard without login redirects to the login page.

Test input or action	Observed result
Correct student / admin / faculty login	Redirected to the matching dashboard.
Incorrect password	Invalid email or password displayed.
Session ID after login	Changed successfully.
Session cookie settings	HttpOnly and SameSite=Lax confirmed.
Anonymous / incorrect-role access	Login redirect / HTTP 403.
Logout / dashboard after logout	Session closed / login required.
Session timeout	Session expired; remember cookie cleared.
Remember me / token rotation	Login restored; a new token was issued.
Old / modified remember token	Rejected.
Last-login timestamp	Updated for all three lab accounts.

All 25 HTTP authentication checks passed. The normal session timeout is 15 minutes. Local tests used HTTP; the HTTPS Secure-cookie flag was not tested in a browser.

Key Questions and Answers

Q1 Are sessions started and destroyed securely

Sessions start with strict mode and cookie-only IDs. HttpOnly and SameSite settings are applied, and the ID is regenerated after login. Logout clears the session, expires the cookie and calls session_destroy().

Q2 Is password_verify() used correctly

Yes. The supplied login password is checked against password_hash from the users table. Correct credentials allow login, while incorrect credentials display a general error message.

Q3 Is unauthorized dashboard access blocked

Yes. PHP checks authentication and the database role before rendering a dashboard. Anonymous users must log in, and users with the wrong role receive HTTP 403.

Q4 Is session timeout implemented

Yes. The last_activity value is checked on authenticated requests. After 15 minutes of inactivity, the session is destroyed and the user is asked to log in again.

Q5 Are admin and student users redirected to appropriate dashboards

Yes. Student accounts open dashboard.php and admin accounts open admin-dashboard.php. Faculty accounts have their own dashboard. All three redirects were tested.

GitHub Repository

https://github.com/DarshilRupani/studenthub-portal
Practical 10 source commit: aebd4ed
Message: Complete Practical 10 session login logout and role-based access

Post Laboratory Work

Submit the login and session source files, sql/practical10.sql and this report containing screenshots for login success, failed login, logout, timeout and unauthorized access. Use the seeded sample accounts to repeat the tests.

Conclusion

Secure login and logout were implemented using PHP sessions. Role-based dashboard access, password verification and inactivity timeout worked correctly in the tests. The intermediate last-login timestamp and advanced remember-me token extensions were also completed.